

Skill 安全与管理工具 V1.0

AI 编码助手 Skill 生态安全检测与可视化管理平台

版本: V1.0

平台: Windows / macOS / Linux

语言: Python 3.10+

目 录

一、项目背景与概述

二、项目地址与运行界面介绍

三、核心功能详解

2.1 Skill 可视化管理

2.2 恶意代码安全检测

2.3 在线批量检测

2.4 代理与网络

2.5 报告导出与操作日志

四、技术架构

3.1 整体架构

3.2 技术栈

3.3 规则体系

五、检测规则详解

4.1 精确模式 (Precise_rules)

4.2 全量模式 (total_rules)

4.3 规则对比

六、支持的平台与 AI 工具

七、使用指南

八、应用场景

九、总结与展望

一、项目背景与概述

随着 AI 编码助手（如 Claude Code、Cursor、GitHub Copilot、Windsurf 等）的快速普及，"Skill"（技能/插件）生态正在蓬勃发展。Skill 是一种扩展 AI 助手能力的模块化组件，通过自定义指令、脚本和配置文件，让 AI 助手具备特定领域的专业能力。然而，Skill 生态的开放性也带来了全新的安全挑战。

2025 年以来，安全社区陆续披露了多起针对 Skill 生态的投毒攻击事件：攻击者通过在 Skill 市场上传包含恶意操作、代码的 Skill，利用 AI 助手的自动执行能力实施凭证窃取、恶意渗透破坏等可能对运行 AI 的系统或 AI 测试的目标造成破坏、数据泄露等重大影响。这些恶意 Skill 往往伪装成"生产力工具"或"开发辅助"，传统的杀毒软件和代码审查流程难以有效识别。

项目定位

Skill 安全与管理工具 V1.0 是一款专为 AI 编码助手 Skill 生态设计的安全检测与可视化管理平台。它集成了 Skill 资产发现、恶意代码静态检测、多平台在线扫描、可视化管理和报告导出等功能，旨在帮助安全研究人员、开发者和企业团队在安装和使用第三方 Skill 之前进行全面的安全性评估。

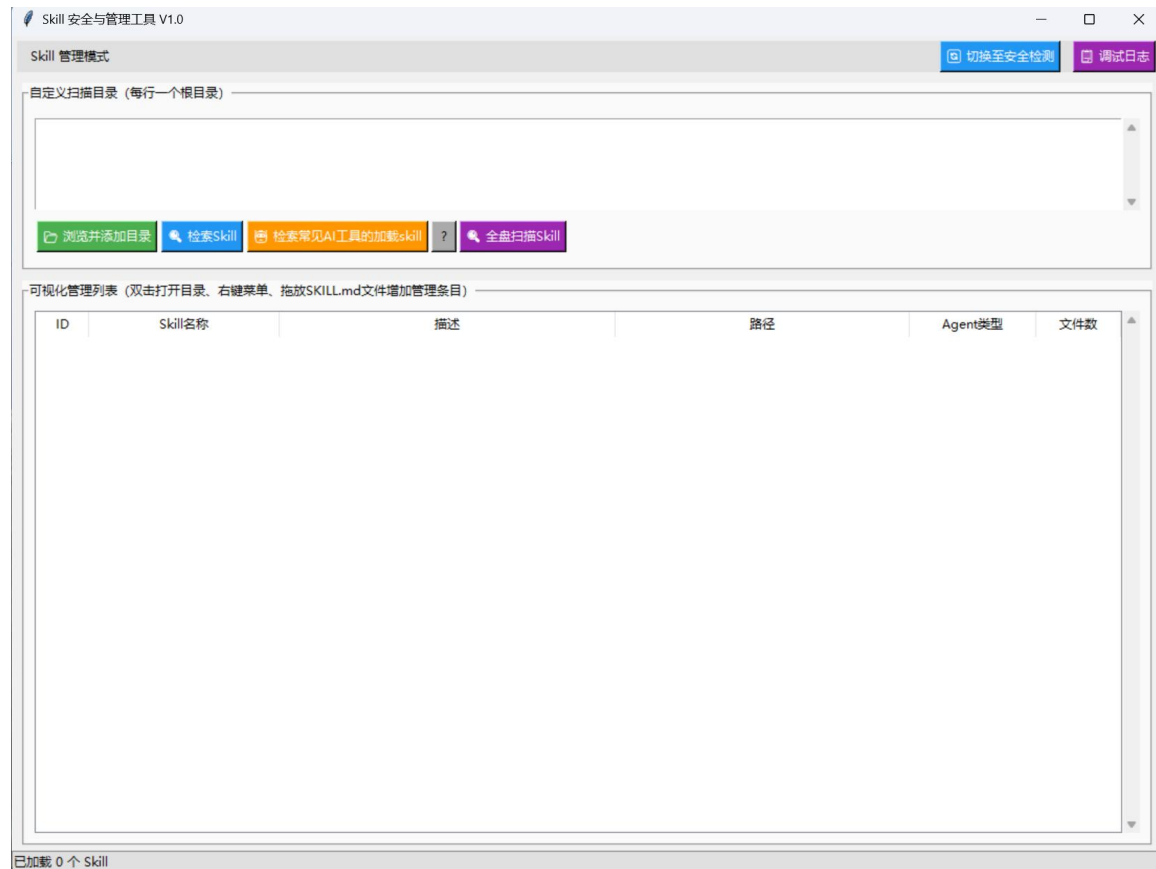
核心能力

- 🔍 Skill 资产发现：支持全盘扫描、常见 AI 工具目录检索、自定义路径递归查找，覆盖 19 种主流 AI 编码助手
- 🔒 恶意代码检测：内置 500+ 条正则规则，覆盖 31 个攻击类别，支持两种扫描模式（全量/精确）
- 🌐 多平台在线检测：支持 GitHub、skills.sh、SkillStore、skill-cn、ClawHub 五大平台的在线批量扫描
- 📁 可视化管理：拖放式 Skill 管理，支持批量操作（删除、打开、发送检测）
- 📄 报告导出：完整的检测报告，含删除操作审计记录

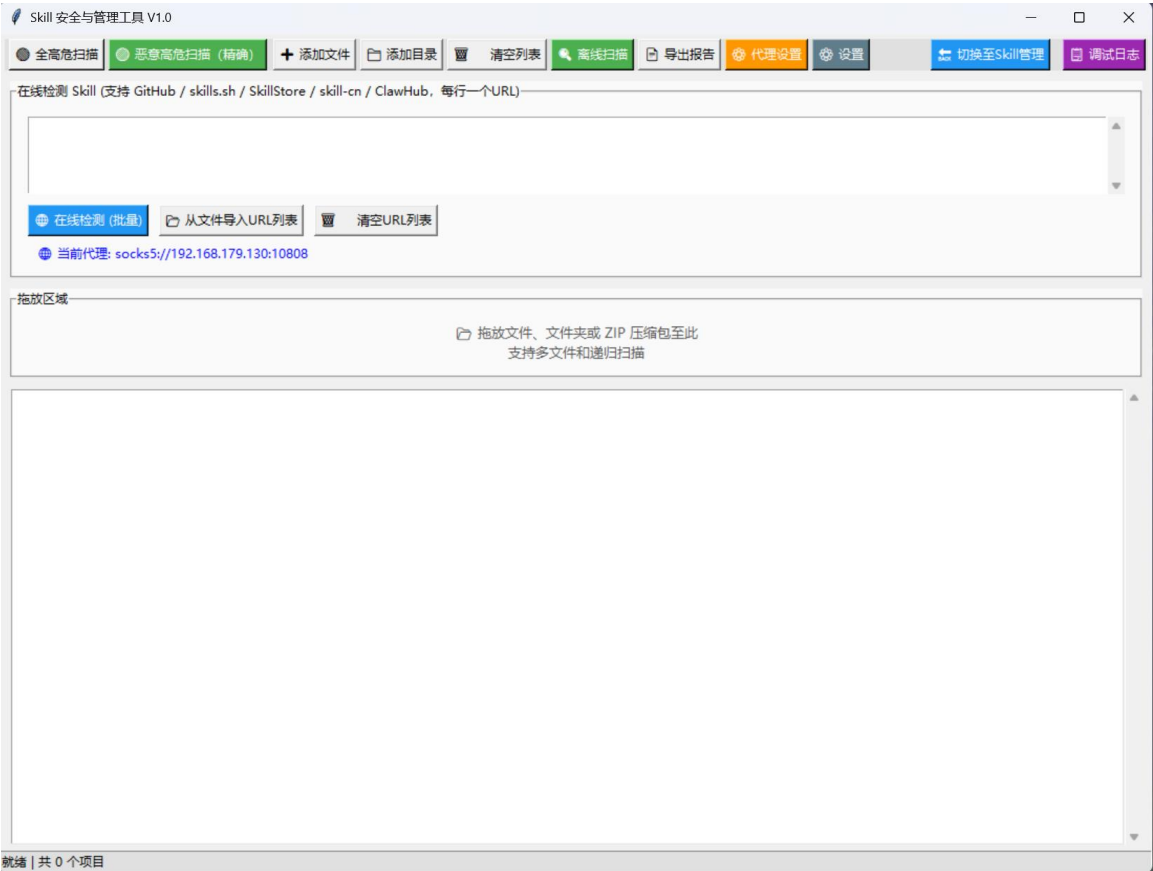
二、项目地址与运行界面介绍

- <https://github.com/Jack-MRJ/Safety-and-Management-Tools-for-Skill/tree/main>

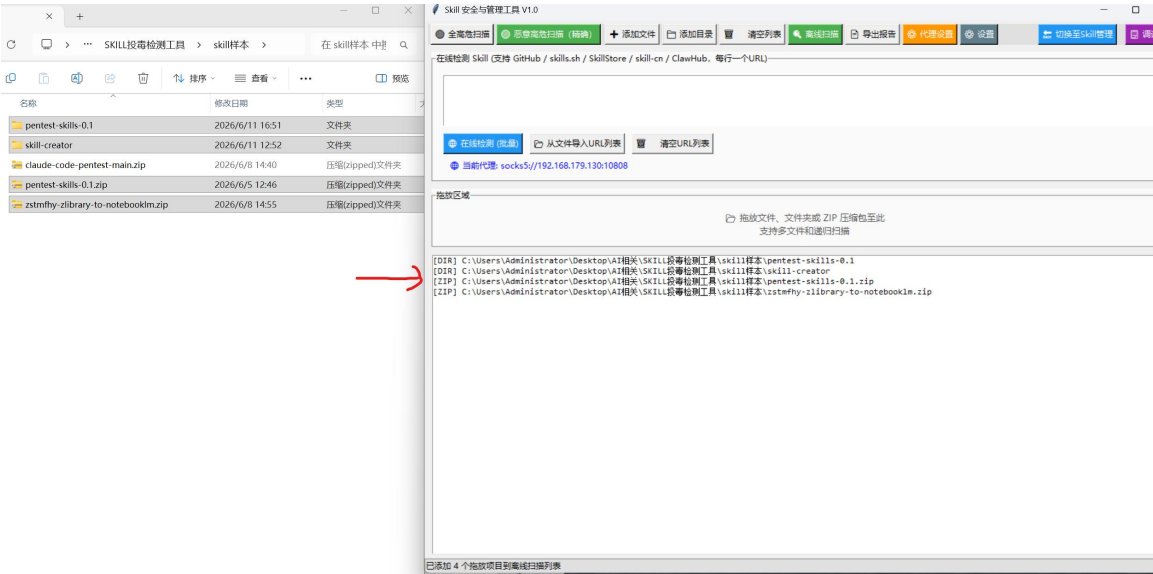
默认 skill 管理界面



默认 skill 安全检测界面



支持拖放多个文件及目录进行检测



支持扫描可能包含对运行 AI 自身系统或 AI 测试目标造成破坏影响的高危操作代码，如下：

扫描内容 - 发现 6 个可疑文件	文件路径	危险等级	命中规则	代码片段	行号
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\sql脚本\pentest-skills-0-1	高危	执行系统命令 (MSSQL) - 命令执行 (xp_cmdshell)	'EXEC xp_cmdshell "dir";'	73	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\sql脚本\pentest-skills-0-1	高危	执行系统命令 (MSSQL) - 命令执行 (xp_cmdshell)	'EXEC master..xp_cmdshell "ping test.com";'	78	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\sql脚本\pentest-skills-0-1	高危	扩权搭建代理 - 高危 (EXEC master..xp_)	'EXEC master..xp_cmdshell "ping test.com";'	79	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\sql脚本\pentest-skills-0-1	高危	执行系统命令 (MSSQL) - 命令执行 (xp_cmdshell)	'EXEC xp_cmdshell "whoami";'	78	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\sql脚本\pentest-skills-0-1	高危	扩权搭建代理 - 高危 (EXEC master..xp_)	'EXEC master..xp_reg_read "HKY_LOCAL_MACHINE\SOFTWARE\Microsoft	78	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\sql脚本\pentest-skills-0-1	高危	执行系统命令 (MSSQL) - 命令执行 (xp_cmdshell)	'EXEC xp_cmdshell "dir";'	90	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\sql脚本\pentest-skills-0-1	高危	执行系统命令 (MSSQL) - 命令执行 (xp_cmdshell)	'EXEC master..xp_cmdshell "dir";'	91	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\sql脚本\pentest-skills-0-1	高危	扩权搭建代理 - 高危 (EXEC master..xp_)	'EXEC master..xp_cmdshell "dir";'	91	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\sql脚本\pentest-skills-0-1	高危	执行系统命令 (MSSQL) - 命令执行 (xp_cmdshell)	'DECLARE @INT INT; WHILE @@ = BEGIN EXEC(@commands+sp_cmshe	78	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\sql脚本\pentest-skills-0-1	高危	删除表 (DROP TABLE) - 破坏数据 (DROP TABLE)	id=1; DROP TABLE users--	115	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\sql脚本\pentest-skills-0-1	高危	删除表 (DROP TABLE) - 破坏数据 (DROP TABLE)	id=1; DROP TABLE users--	123	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\Offline_detection(scan_202	高危	执行系统命令 (MSSQL) - 命令执行 (xp_cmdshell)	'EXEC xp_cmdshell "dir";'	78	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\Offline_detection(scan_202	高危	执行系统命令 (MSSQL) - 命令执行 (xp_cmdshell)	'EXEC master..xp_cmdshell "ping test.com";'	78	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\Offline_detection(scan_202	高危	扩权搭建代理 - 高危 (EXEC master..xp_)	'EXEC master..xp_cmdshell "ping test.com";'	78	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\Offline_detection(scan_202	高危	执行系统命令 (MSSQL) - 命令执行 (xp_cmdshell)	'EXEC xp_cmdshell "whoami";'	79	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\Offline_detection(scan_202	高危	扩权搭建代理 - 高危 (EXEC master..xp_)	'EXEC master..xp_reg_read "HKY_LOCAL_MACHINE\SOFTWARE\Microsoft	78	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\Offline_detection(scan_202	高危	执行系统命令 (MSSQL) - 命令执行 (xp_cmdshell)	'EXEC xp_cmdshell "dir";'	90	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\Offline_detection(scan_202	高危	执行系统命令 (MSSQL) - 命令执行 (xp_cmdshell)	'EXEC xp_cmdshell "dir";'	91	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\Offline_detection(scan_202	高危	扩权搭建代理 - 高危 (EXEC master..xp_)	'EXEC master..xp_cmdshell "dir";'	91	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\Offline_detection(scan_202	高危	执行系统命令 (MSSQL) - 命令执行 (xp_cmdshell)	'DECLARE @INT INT; WHILE @@ = BEGIN EXEC(@commands+sp_cmshe	78	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\Offline_detection(scan_202	高危	删除表 (DROP TABLE) - 破坏数据 (DROP TABLE)	id=1; DROP TABLE users--	115	
C:\Users\Administrator\Desktop\A组工具\SQL数据库检查工具\Offline_detection(scan_202	高危	删除表 (DROP TABLE) - 破坏数据 (DROP TABLE)	id=1; DROP TABLE users--	123	

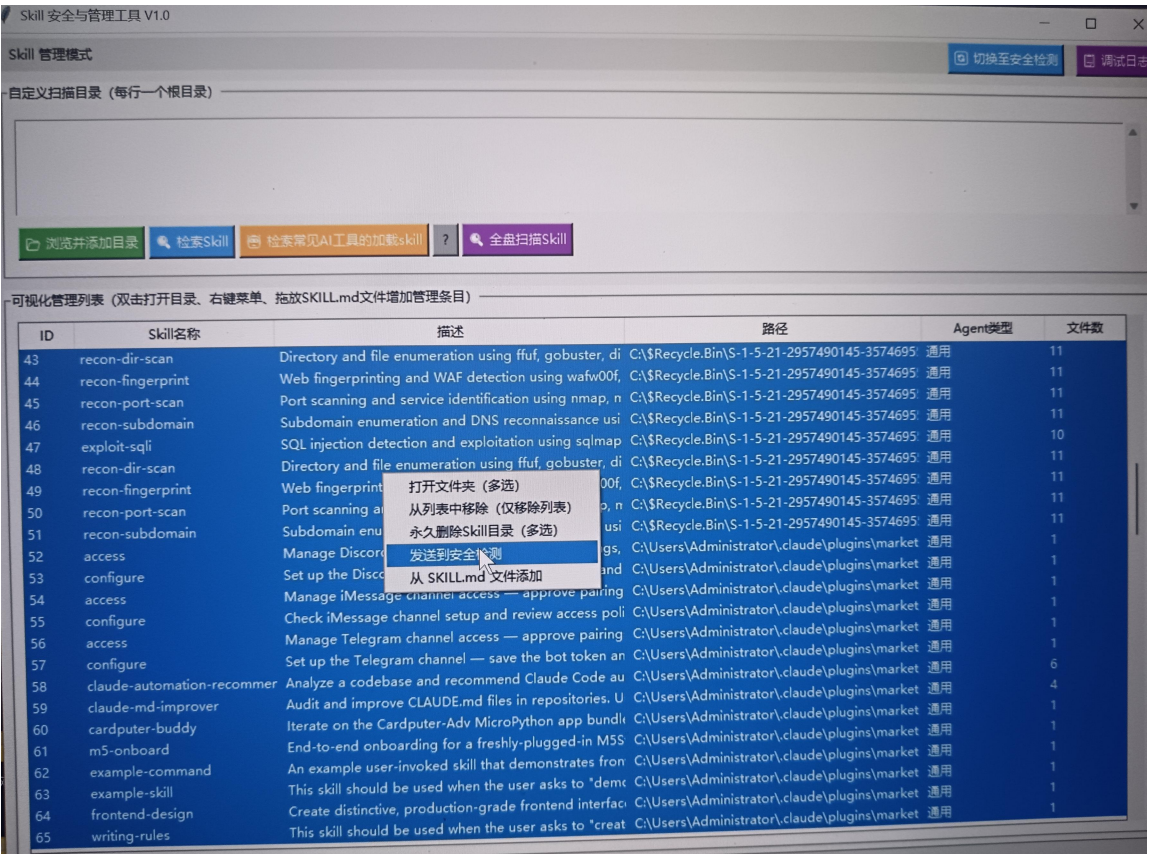
默认装了 vscode 后双击可直接打开文件对应的行:

The screenshot displays a manual SQL injection attack in progress. The left pane shows the script `manual_sql_injection.py` with comments and code. The right pane shows the output of the script, displaying a list of detected vulnerabilities and the corresponding SQL injection payloads. The output includes details such as the file path, the type of vulnerability (e.g., 'SQL Injection'), the command executed, and the result of the injection.

也可 ctrl+a 右击删除这些恶意代码行:

文件路径	危害	命中规则	代码片段
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	执行系统命令 (MSSQL) - 命令执行 (x) ; EXEC xp_cmdshell ('dir')--	73
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	执行系统命令 (MSSQL) - 命令执行 (x) ; EXEC master..xp_cmdshell '76	76
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	扩展存储过程 - 高危 (EXEC master..x ; EXEC master..xp_cmdshell '78	78
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	执行系统命令 (MSSQL) - 命令执行 (x) ; EXEC xp_cmdshell 'whoami' 79	79
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	扩展存储过程 - 高危 (EXEC master..x ; EXEC master..xp_reg_read '92	92
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	执行系统命令 (MSSQL) - 命令执行 (x) ; EXEC xp_cmdshell ('dir')-- 90	90
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	执行系统命令 (MSSQL) - 命令执行 (x) ; EXEC master..xp_cmdshell '91	91
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	扩展存储过程 - 高危 (EXEC master..x ; EXEC master..xp_cmdshell '91	91
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	执行系统命令 (MSSQL) - 命令执行 (x) ; DECLARE @i INT=1; WHILE 64	64
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	删除表 (DROP TABLE) - 破坏数据 (Df id=1; DROP TABLE users-- 115	115
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	删除表 (DROP TABLE) - 破坏数据 (Df id=1; DROP TABLE users-- 123	123
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	执行系统命令 (MSSQL) - 命令执行 (x) ; EXEC xp_cmdshell ('dir')-- 73	73
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	执行系统命令 (MSSQL) - 命令执行 (x) ; EXEC master..xp_cmdshell '78	78
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	扩展存储过程 - 高危 (EXEC master..x ; EXEC master..xp_cmdshell '79	79
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	执行系统命令 (MSSQL) - 命令执行 (x) ; EXEC xp_cmdshell 'whoami' 78	78
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	扩展存储过程 - 高危 (EXEC master..x ; EXEC master..xp_reg_read '82	82
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	执行系统命令 (MSSQL) - 命令执行 (x) ; EXEC xp_cmdshell ('dir')-- 90	90
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	执行系统命令 (MSSQL) - 命令执行 (x) ; EXEC master..xp_cmdshell '91	91
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	扩展存储过程 - 高危 (EXEC master..x ; EXEC master..xp_cmdshell '91	91
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	执行系统命令 (MSSQL) - 命令执行 (x) ; DECLARE @i INT=1; WHILE 64	64
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	删除表 (DROP TABLE) - 破坏数据 (Df id=1; DROP TABLE users-- 115	115
C:\Users\Administrator\Desktop\AI\相关\SKILL\投毒检测工具	高	删除表 (DROP TABLE) - 破坏数据 (Df id=1; DROP TABLE users-- 123	123

还有 skill 统一管理功能，支持将管理的 skill 右键直接调用 skill 检测模块进行 skill 安全性扫描：



双击可打开 skill 对应的目录，可在这里随时删除任意管理的 skill 所在目录及其中的所有内容，实现 skill 管理+安全检测 2 大需求，还有很多细节功能，也支持自定义恶意代码识别规则，在 Precise_rules.py 和 total_rules.py 这 2 大规则库进行添加即可。

三、核心功能详解

3.1 Skill 可视化管理

工具提供完整的 Skill 资产全生命周期管理能力，帮助用户掌握系统中所有已安装的 Skill 情况：

自定义目录检索

用户可指定任意多个根目录，工具递归扫描所有子目录，自动识别包含 SKILL.md 文件的 Skill 项目。检索结果以表格形式展示，包含 Skill 名称、描述、路径、Agent 类型和文件数量等信息。

常见 AI 工具一键检索

内置 19 种主流 AI 编码助手的 Skill 默认安装路径，一键检索所有已安装 Skill：

AI 工具	Skill 默认路径
Claude Code	~/claude/skills
Codex	~/codex/skills
Cursor	~/cursor/skills
Windsurf	~/windsurf/skills
GitHub Copilot	~/copilot/skills
Gemini CLI	~/gemini/skills
Cline	~/cline/skills
Roo Code	~/roo/skills
Aider	~/aider/skills
CodeBuddy	~/codebuddy/skills

全盘扫描

支持遍历系统所有磁盘分区（Windows 下遍历 C:-Z: 盘，Linux 下扫描 /home、/usr、/opt 等目录），发现所有 SKILL.md 文件。扫描过程实时显示进度和发现结果。

拖放式添加

支持将 SKILL.md 文件直接拖放到管理窗口，自动解析 Skill 名称、描述等元信息，一键添加到管理列表。

右键菜单操作

- 打开文件夹（支持多选批量打开）

- 从列表移除（仅移除记录，不删除实际文件）
- 永久删除 Skill 目录（物理删除，含确认提示）
- 发送到安全检测（将 Skill 目录加入离线扫描队列）
- 从 SKILL.md 文件手动添加

3.2 恶意代码安全检测

安全检测是工具的核心功能，提供离线扫描和在线批量检测两种模式。

离线扫描

支持对本地文件、目录和 ZIP 压缩包进行扫描：

- 文件扫描：逐行正则匹配，精确定位恶意代码所在行号
- 目录递归扫描：遍历目录下所有文件，包含对 ZIP 嵌套解压的支持
- ZIP 压缩包：自动解压到临时目录后扫描全部内容
- 结果展示：表格形式显示文件路径、危险等级、命中规则、代码片段、行号
- 双击跳转：双击结果条目可直接在 VSCode / Sublime Text / 记事本中打开对应文件并定位到指定行
- 右键删除：支持从源文件中批量永久删除恶意代码行

双模式扫描

工具提供两种扫描模式，用户可根据实际需求灵活切换：

模式	规则文件	规则数量	特点	适用场景
● 全高危扫描	total_rules.py	380+ 条	覆盖面广，误报率相对较高	全面安全审计
恶意高危扫描 (精确)	Precise_rules.py	360+ 条	聚焦高危操作，精确度更高	日常检测、快速筛查

规则文件支持热更新：将自定义规则文件放在 exe 同目录即可覆盖内置规则，无需重新打包。

3.3 在线批量检测

支持对 Skill 市场中的在线 Skill 进行远程下载和自动扫描，覆盖五大主流平台：

平台	检测方式
----	------

GitHub	直接下载仓库 ZIP（支持 main/master 分支），自动解压扫描
skills.sh	提取页面中的 GitHub 仓库链接，级联检测
SkillStore	调用 API 下载 Skill 包，失败时回退到 GitHub 页面提取
skill-cn	调用下载 API，失败时回退到页面 GitHub 链接提取
ClawHub	支持 convex.site 直链下载和 artifact API 两种方式，含 .tgz 解压支持

批量检测采用多线程并发处理，每个 URL 在独立的标签页中展示扫描进度和结果。支持从文本文件导入 URL 列表，实现大规模 Skill 批量审查。

3.4 代理与网络

工具内置完整的代理支持，满足不同网络环境下的检测需求：

- 支持 HTTP / HTTPS / SOCKS5 三种代理协议
- 支持用户名/密码认证
- 内置连通性测试功能（通过 Google 测试代理可用性和延迟）
- SOCKS5 代理自动检测 PySocks 依赖并提示安装

3.5 报告导出与操作日志

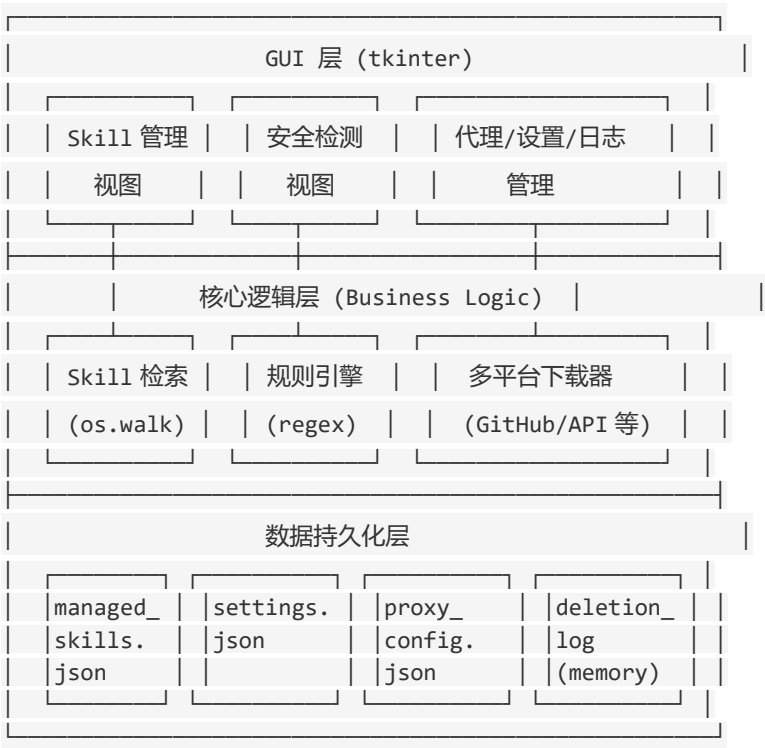
所有检测和操作均有完整的审计记录：

- 调试日志窗口：实时查看扫描细节、网络请求、错误信息
- 删除操作记录：每次恶意代码删除均记录时间、文件路径、行号、代码片段和命中规则
- 报告导出：生成 TXT 格式检测报告，含在线/离线扫描目标和删除操作汇总
- 临时文件管理：可配置扫描完成后自动清理或保留临时文件

四、技术架构

4.1 整体架构

工具采用单文件 GUI 架构，基于 Python tkinter 构建，通过模块化设计实现清晰的职责分离：



4.2 技术栈

技术组件	用途说明
Python	3.10+（兼容 3.8+），核心开发语言
tkinter	Python 标准 GUI 库，实现跨平台图形界面
tkinterdnd2	拖放支持组件，实现文件拖放到窗口的功能
requests	HTTP 客户端，用于在线检测和 API 调用
httpx	异步 HTTP 客户端，补充网络请求能力
importlib	动态模块加载，实现规则文件热加载与热切换
threading	多线程并发，实现在线批量检测不阻塞 UI
PyInstaller	打包工具，生成单文件独立可执行程序
re (正则)	Python 标准正则引擎，驱动恶意模式匹配

4.3 规则体系

工具采用"规则与引擎分离"的架构设计。检测规则以独立 Python 文件的形式存在，引擎通过 `importlib` 动态加载，实现了规则的热切换和用户自定义扩展。

核心设计要点：

- 规则文件定义 `MALICIOUS_PATTERNS` 字典，key 为正则表达式，value 为中文风险描述
- 扫描时逐行读取文件，用全部规则依次匹配每一行，记录匹配的行号、内容和规则描述
- 规则支持不区分大小写匹配 (`(?i)` 标志)，兼容多语言特征 (SQL、Shell、Python、PowerShell 等)
- 规则文件加载采用双重查找策略：优先 exe 同目录（支持自定义覆盖），回退到内置打包资源

五、检测规则详解

工具内置两套规则体系，分别适用于不同场景。以下为规则分类的完整说明：

5.1 精确模式 (Precise_rules.py) — 31 类高危规则

精确模式聚焦于具有实际破坏性、可导致数据丢失、系统受损或权限被夺取的高危操作，排除了正常的无害操作，适用于渗透测试、自动化脚本等任何类型的 Skill 检测。

规则类别	典型检测项	防护目标
1. 数据库破坏	DROP TABLE/DB、TRUNCATE、无条件 DELETE、xp_cmdshell、Redis FLUSHALL 等	防止数据被恶意删除或篡改
2. 文件破坏/覆写	rm -rf /、dd 覆写磁盘、format C:、shutil.rmtree 关键目录	防止系统文件被破坏
3. 反弹 Shell/后门	socket+dup2、bash TCP 反弹、Python/Perl/Ruby 反弹 Shell、MSFvenom、Webshell	检测远程控制后门
4. 持久化/自启动	crontab 定时下载、systemd 服务、Windows 注册表 Run 键、macOS LaunchAgent	防止恶意程序持久驻留
5. 权限提升	sudo su、setuid、CVE 漏洞利用、PowerShell 绕过 UAC	检测提权攻击
6. 凭据窃取	读取/etc/shadow、SSH 私钥、AWS 凭证、环境变量密钥、webhook 外发	防止敏感信息泄露
7. 破坏性命令	kill -9、shutdown、iptables 阻断、禁用网卡、rm -rf / --no-preserve-root	检测拒绝服务攻击
8. 容器逃逸	docker --privileged、nsenter、chroot、mount bind 宿主机目录	检测容器逃逸行为
9. 云资源破坏	aws s3 rm、EC2 终止、RDS 删除、Terraform destroy -auto-approve	防止云资源被恶意销毁
10. 供应链投毒	curl 管道 sudo 执行、pip 非官方源安装、npm --unsafe-perm	检测依赖投毒攻击
11. AI 自然语言注入	ignore all previous instructions、角色劫持、系统提示覆盖	检测针对 AI 的提示注入
12. Windows 特有	Defender 排除路径、net user 创建用户、vssadmin 删除卷影、bcdedit 禁用恢复	Windows 系统专项检测
13. macOS 特有	osascript 提权、launchctl 持久化、csrutil 禁用 SIP、kextload 内核扩展	macOS 系统专项检测
14. 数据库隐蔽后门	触发器后门、存储过程后门、ALTER DATABASE 恢复模式	检测数据库层面的高级后门
15. 云权限篡改	AWS IAM 提权、GCP 服务账号密钥创建、Azure Owner 角色授予	检测云平台权限滥用

16. AI 模型投毒	修改 API 密钥环境变量、写入 Skill 目录植入、修改模型权重文件	检测针对 AI 环境的高级攻击
17. CI/CD 篡改	sed 修改 GitLab CI、追加 GitHub Actions 恶意步骤、Jenkins 恶意 Groovy	检测 CI/CD 流水线投毒
18. 网络破坏	iptables 阻断 SSH/DNS、nftables 阻断入站、修改默认网关、ARP 欺骗	检测网络层面的破坏
19. 加密勒索	AES 加密文件、比特币地址、GPG 对称加密批量文件	检测勒索软件行为
20. 反检测技巧	base64 解码执行、openssl 解密、十六进制解码、静默后台执行	检测混淆和隐藏技术
21-25	进程注入、凭据转储(Mimikatz)、网络嗅探、隐蔽隧道(DNS/ICMP/HTTP)、Linux 能力滥用	检测 APT 级别的高级攻击技术
26-30	AI 模型/向量数据库篡改、匿名文件外发、日志清除/反取证、虚拟机逃逸、开发工具配置篡改	补充检测覆盖
31. 数据库脱裤	SELECT * 无 LIMIT、mysqldump 全库导出、MongoDB export、API 大分页遍历	检测批量数据窃取

5.2 全量模式 (total_rules.py) — 基础 + 10 大补充类别

全量模式在精确模式的基础上，额外增加了 10 个补充类别，覆盖面更广，适用于全面的安全审计场景：

补充类别	检测内容	补充原因
补充 1. 浏览器自动化	Playwright/Puppeteer/Selenium 截图、PDF、Cookie、JavaScript 执行	检测浏览器层面的信息窃取
补充 2. 凭据窃取补充	数据库连接字符串、Docker 配置、npmrc、Terraform 凭证、各类 API 密钥	覆盖更多凭据泄露场景
补充 3. 容器与云删除	kubectl delete、helm uninstall、多云厂商资源删除、IaC 销毁	检测容器和云资源破坏
补充 4. 依赖安装补充	curl 管道 sudo 执行、非官方源安装、npx 运行最新包	检测更多供应链攻击手法
补充 5. 系统高危命令	crontab 编辑、iptables 修改、systemctl 操作、数据库全库导出	检测系统级高危操作
补充 6. 网络隧道与 C2	.onion 暗网连接、Tor 代理、SSH 隧道、FRP/ngrok 内网穿透	检测 C2 通信信道
补充 7. 多用户环境	su 切换用户、useradd 创建用户、usermod 加入 sudo 组、passwd 修改密码	检测横向移动和提权
补充 8. 脚本隐藏技巧	chattr 防删除、base64/openssl/xxd 解码执行、screen/tmux 后台会话	检测混淆持久化

补充 9. 提示注入增强	ignore previous instructions、角色劫持、重新编程模式、诱导点击	全面检测 AI 注入攻击
补充 10. CI/CD 篡改	GitHub Actions、GitLab CI、Jenkins、CircleCI、Travis CI 等	全面检测 CI/CD 攻击面

5.3 两种模式对比

对比维度	全量模式 (total_rules)	精确模式 (Precise_rules)
规则总数	380+ 条	360+ 条
规则类别	基础 10 类 + 10 大补充	31 个精细分类
误报率	相对较高（如正常的 HTTP 请求也会匹配）	较低（排除了常见的正常操作）
覆盖面	广（含浏览器自动化、系统侦察等）	聚焦（仅高危破坏性操作）
检测深度	浅而广	深而准
推荐场景	首次全面审计、安全研究	日常检测、快速筛查、CI 集成

六、支持的平台与 AI 工具

在线 Skill 平台

平台	URL	检测方式
GitHub	github.com	仓库 ZIP 下载 + 解压扫描
skills.sh	skills.sh	页面解析 → GitHub 级联
SkillStore	skillstore.io	API 下载 / 页面回退
skill-cn	skill-cn.com	API 下载 / 页面回退
ClawHub	clawhub.ai	convex.site 直链 / artifact API

支持的 AI 编码助手

工具支持对以下 19 种主流 AI 编码助手的 Skill 目录进行自动检索和安全管理：

- Claude Code、Codex、Cursor、Windsurf、GitHub Copilot
- Continue、Gemini CLI、Cline、Kiro、Qoder
- Roo Code、Aider、Hermes Agent、CodeBuddy、Tabby
- OpenHands、Antigravity、Lingma、Qodo

七、使用指南

快速开始

1. 环境准备

```
pip install requests tkinterdnd2 PySocks urllib3
```

2. 运行程序（源码方式）

```
python 3.2.py
```

3. 运行程序（打包 exe 方式）

```
双击 Skill 安全管理工具 V1.0.exe
```

典型工作流程

场景一：检测本地已安装的 Skill

- 切换到 Skill 管理视图 → 点击"检索常见 AI 工具的加载 skill"
- 在结果窗口中选择可疑的 Skill → 点击"添加到可视化管理"
- 右键 Skill → "发送到安全检测"
- 切换到安全检测视图 → 点击"离线扫描"
- 查看结果，对恶意代码行右键"删除选中行"

场景二：在线审查 Skill 市场

- 切换到安全检测视图
- 在在线检测文本框中粘贴 Skill URL（每行一个）
- 配置代理（如需要）→ 点击"在线检测 (批量)"
- 在各标签页查看扫描结果 → 右键删除恶意代码
- 导出报告保存审计记录

场景三：审查第三方 Skill 包

- 将 Skill 文件/文件夹/ZIP 直接拖放到安全检测窗口
- 选择扫描模式（全量/精确）
- 点击"离线扫描"查看结果
- 双击结果条目跳转到 IDE 查看上下文

八、应用场景

企业安全团队

在企业内部部署，对所有员工使用的 AI 编码助手 Skill 进行定期安全审查。通过全盘扫描发现未授权的 Skill 安装，通过精确模式快速筛查高风险 Skill，结合报告导出功能建立 Skill 安全审计档案。

安全研究人员

对 Skill 市场（GitHub、skills.sh 等）中的热门 Skill 进行批量安全分析。利用在线批量检测功能，一次性审查数百个 Skill，发现潜在的供应链攻击模式。规则体系可作为 Skill 安全研究的基线参考。

个人开发者

在安装第三方 Skill 之前，通过离线扫描快速判断其安全性。拖放操作和右键删除功能使检测和清理流程极为便捷。双击跳转 IDE 功能帮助开发者深入审查可疑代码的上下文。

CI/CD 集成

将工具的检测引擎集成到 CI/CD 流水线中，在 Skill 发布或部署前自动进行安全扫描。精确模式适合作为 CI Pipeline 中的质量门禁，拦截包含高危操作的 Skill。

Skill 市场运营方

在上架审核流程中使用工具对新提交的 Skill 进行快速初筛。全量模式可用于深度审查，精确模式可用于日常自动审核。

九、总结与展望

项目价值

Skill 安全与管理工具 V1.0 填补了 AI 编码助手 Skill 生态在安全检测领域的空白。它提供了一套完整的"发现 → 检测 → 管理 → 审计" workflow，将 Skill 安全管理从被动响应转变为主动防御。

- 全面的规则覆盖：500+ 条检测规则，31 个攻击类别，覆盖从数据库破坏到 AI 提示注入的全攻击面
- 多平台支持：覆盖五大 Skill 市场和 19 种 AI 编码助手的 Skill 路径
- 用户友好：拖放操作、双击跳转 IDE、右键删除等交互设计大幅降低使用门槛
- 灵活扩展：规则与引擎分离，热加载和热切换，支持用户自定义规则
- 生产可用：PyInstaller 单文件打包，双击即用，无需 Python 环境

未来规划

- 动态沙箱分析：集成沙箱环境，对可疑 Skill 进行动态行为分析，弥补静态检测的盲区
- 更精准的查杀规则：引入更多实际可能造成危害的规则，删除无用规则，降低误报率
- 社区规则库：建立开放的规则贡献机制，社区共同维护和更新检测规则
- 更多平台支持：扩展对更多 Skill 市场和 AI 工具的支持
- Web 管理面板：提供 B/S 架构版本，支持团队协作和集中化管理
- 实时监控：对 Skill 目录进行文件监控，Skill 文件变更时自动触发安全扫描
- AI 恶意流量拦截：识别到 AI 对外发起恶意流量后进行拦截并记录事件，返回给 AI 违规指令，数据包包含恶意操作，纠正 AI 行为。

免责声明

本工具仅供安全研究和授权测试使用，主要用于辅助用户对下载的 Skill 项目进行安全性检查。请勿用于非法目的，因非法使用或二次修改此工具对任何 Skill 管理网站造成不良影响，作者概不负责。